

Informe Ejecutivo sobre el Incidente de Hackeo a Equifax – 2017

**Análisis de impacto, respuesta institucional y respuesta posterior
al incidente**

Mtro. Servando López Contreras

Personal que presenta el informe:

181850 Manuel Eduardo Hernández Gaytan

182455 – Fabiola Calvillo Galván

181629 - José Carlos Ojeda Camacho

184286 - Rodríguez Jiménez Quetzal Olin

181512 Jorge Abraham Castelo Curioca

181583 Angel Aaron Acuña Quezada

183511 David Campos Morado

Tabla de contenidos

Tabla de contenidos	1
Introducción	2
Informe grupal	3
Vector de entrada	3
Duración del incidente	3
Contexto general del ataque	4
Tablas técnicas y de costos	4
Tabla técnica del ataque.....	4
Evaluación del impacto (Modelo CIA)	5
Cálculo del costo total del ciber ataque.....	6
Lecciones aprendidas y Recomendaciones.....	7
Conclusiones	8
Fuentes consultadas.....	8

Introducción

Durante la investigación realizada en torno al incidente de seguridad ocurrido en julio de 2017, se identificó que atacantes lograron acceso no autorizado al portal de disputas en línea de Equifax. Este portal almacenaba documentos sensibles utilizados para resolver reclamaciones de consumidores, lo que permitió a los intrusos obtener información personal de aproximadamente 145.5 millones de personas.

El análisis interno de la compañía reveló cuatro factores críticos que facilitaron el ataque: deficiencias en la identificación y detección de amenazas, falta de segmentación en el acceso a las bases de datos y debilidades en la gobernanza de datos. A partir de estos hallazgos, Equifax implementó medidas de mitigación, reforzó sus protocolos de seguridad y emprendió acciones para notificar a los individuos afectados.

Este informe presenta un resumen ejecutivo del incidente, sus impactos y el análisis posterior al ataque, con el objetivo de ofrecer a la alta dirección una visión clara y estratégica sobre los riesgos y las medidas de prevención necesarias para proteger la información crítica de la organización.

Informe grupal

Vector de entrada

El ingreso de los atacantes fue debido a la vulnerabilidad del exploit dando como resultado acceso mediante este.

Según el reporte expuesto por Kaspersky los atacantes aprovecharon el exploit CVE-017-5638 de la página web apache siendo la forma principal del ataque dando como resultado que se mantuvieron dentro del sistema por varios días así mismo infiltrándose de manera cautelosa para evitar ser descubiertos, Esposito (2017).

Duración del incidente

13 Mayo 2017- Los atacantes acceden de forma no autorizada a través de una vulnerabilidad en el servicio web usado en los servidores de Equifax.

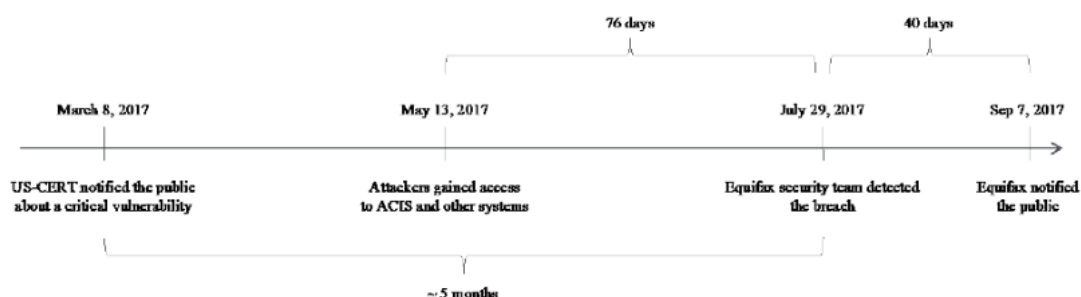
30 Julio 2017- El equipo encargado de la seguridad continúa observando actividad sospechosa en respuesta sacaron de la red la aplicación web una vez descubierto el vector de ataque la aplicación fue parchada y puesta en línea

2 Agosto 2017- Equifax contacta a la firma de seguridad cibernética “Mandiant” para solicitar apoyo con un análisis forense y determinar el alcance del ataque.

El resultado de Mendiand revela que 143 millones de clientes en Estados Unidos fueron afectados entre los datos se encuentran nombres, números de seguro social, fechas de nacimiento, aproximadamente 209,000 números de tarjeta de crédito.

7 Septiembre 2017- Equifax dio el anuncio del incidente y dio a conocer públicamente los datos filtrados. La compañía habilito un sitio web y herramientas para que verificaran si su información personal había sido comprometida.

Equifax. (2017). *Equifax Cybersecurity Incident*. Recuperado de <https://www.equifaxsecurity2017.com/>



Contexto general del ataque

El ataque ocurrió en el año 2017, en Estados Unidos de América y la entidad afectada fue la empresa multinacional EQUIFAX. En cuanto a sus condiciones de ciberseguridad previas, esta empresa ya presentaba varios problemas serios en materia de ciberseguridad. Tenía fallas estructurales que hicieron el ataque posible. Entre los principales factores que facilitaron el ataque estaban:

- Mala gestión de parches: el fallo por el que los atacantes aprovecharon ya tenía solución disponible meses atrás, pero no se aplicó a tiempo.
- Poca preparación para notificar el incumplimiento: esto provocó que se tardaran meses en informar a los afectados una vez descubierto el ataque.
- Políticas de seguridad de la información débiles: no se aplicaban de forma consistente.

Tablas técnicas y de costos

Tabla técnica del ataque

Elemento	Descripción
Tipo de ataque	Databreach
Actor o grupo atacante	Miembros del Ejército Popular de Liberación de China
Vector de entrada	Solicitudes HTTP malintencionadas al servicio ACIS.

Vulnerabilidad explotada	CVE-2017-5638 - Gestión de excepciones y generación de mensajes de error incorrectas por parte del analizador Jakarta Multipart en Apache Struts 2.
Etapas del ataque (MITRE ATT&CK)	1. Irrumpieron en el sistema conforme a la explotación de la falla de apache struct 2. Ejecutaron comandos remotos vía servidor web 3. Realizaron una exploración exhaustiva en la red interna para la identificación de base de datos de texto plano persistiendo en el sistema hasta el descubrimiento 4. Accedieron a otros servidores relacionados con las credenciales comprometidas extraídas durante su exploración en el sistema 5. Recopilaron datos sensibles de clientes en ráfagas de consultas para evitar sospechas
Sistemas o servicios comprometidos	El servicio de Automated Consumer Interview System (ACIS), 51 bases de datos con información de identificación personal y el framework web de Apache Struts2.
Duración del incidente	76 días de exfiltración no detectada, iniciado el 13 de mayo del 2017 y culminando el 7 de septiembre del 2017.
Mecanismos de detección y respuestas	1. La detección de la infiltración se debe a una actualización del certificado SSL que había expirado 9 meses antes del ataque. 2. Aislamiento y desconexión de la aplicación ACIS. 3. Mandiant fue contratada el 2 de agosto de 2017 por la firma de abogados de Equifax para dirigir la investigación forense independiente tras el descubrimiento de la brecha. 4. Equifax implemento nuevos procesos para gestionar la identificación y solución de vulnerabilidades. 5. Desarrollo nuevas políticas de protección de datos e implementó nuevas herramientas de monitoreo de trafico de red. 6. Implemento un nuevo marco de controles de seguridad y controles más estrictos para el acceso a sistemas, aplicaciones y redes específicos.

Evaluación del impacto (Modelo CIA)

Principio	Descripción del impacto	Evidencia del caos
Confidencialidad	El databreach contenía información de	<u>GAO-18-559, DATA PROTECTION: Actions Taken by Equifax and Federal Agencies in Response to the 2017</u>

	identificación personal como nombres, números de seguro social, fechas de nacimiento, direcciones y, en algunos casos, números de licencia de conducir.	Breachhttps://www.gao.gov/assets/gao-18-559.pdf
Integridad	Se exfiltró información de 3 bases de datos relacionadas al servicio ACIS, además de otras 48 sin relación. Se vulneró el servicio Automated Consumer Interview System (ACIS).	GAO-18-559, DATA PROTECTION: Actions Taken by Equifax and Federal Agencies in Response to the 2017 Breach
Disponibilidad	Se interrumpió el servicio Automated Consumer Interview System (ACIS) por parte de la empresa después del incidente.	GAO-18-559, DATA PROTECTION: Actions Taken by Equifax and Federal Agencies in Response to the 2017 Breach

Cálculo del costo total del ciber ataque

Tipo de costo	Descripción	Estimacion (MXN)
Pérdidas operativas	Se tuvo que desconectar el portal de disputas en línea, este canal era una operación importante de su proceso de atención al cliente. Al ceder el control de la red a Mndiant para el análisis forense, se tuvo que parar toda operación tecnológica interna. La renuncia forzada de Richard Smith (CEO), el CIO y el CSO	1,504 millones de pesos mexicanos

	afectó la estructura de la empresa, se pagaron honorarios y pensión.	
Daños reputacionales	Las acciones de Equifax siguieron bajando hasta tocar un mínimo de 92,98 dólares, lo que supuso la pérdida del 34% del valor de mercado de 17.500 millones de dólares de la compañía.	94000 millones de pesos mexicanos
Costos técnicos	Honorarios de firmas externas de ciberseguridad/forense (Mandiant), contratación de asesores, modernización de infraestructura e inversión obligatoria en seguridad de TI	23,500 millones de pesos
Costos legales / regulatorios	Equifax pagará al menos 525 millones de dólares y como máximo unos 700 millones de dólares	13,536 millones de pesos
Pago de rescate o extorsión	No se reportó un pago de rescate a los atacantes. El incidente consistió principalmente en el acceso no autorizado, extracción de información personal y propiedad intelectual. El DOJ acusó a cuatro integrantes del PLA chino de participar en la intrusión.	NA
TOTAL ESTIMADO		131 mil millones de pesos

Lecciones aprendidas y Recomendaciones

- Fallas críticas detectadas (técnicas o humanas).

Unas de las principales fallas visibles fue el software desactualizado siendo esta una falla técnica-humana puesto a que la actualización pudo ser de forma automática o manual

Una falta de comunicación para una facilidad de reporte

Falta o nulo monitoreo de peticiones de logeos

La renovación del certificado del inspector interno esto se debió la infiltración

Políticas de seguridad insuficientes para una repeler inmediatamente el atacante

Negligencia del personal

- Buenas prácticas y políticas que habrían reducido el daño.

Un sistema de seguridad más robusto así mismo la verificación constante de actualizaciones de seguridad con aplicaciones o servicios trabajados

Realizar una reestructuración para independizar los sistemas de base de datos para así evitar datos comprometidos

Descartar las credenciales de administradores o empleados en sistemas de texto plano en los servidores

- Recomendaciones aplicables al contexto mexicano o latinoamericano.
 - Gestión de parches y vulnerabilidades como prioridad estratégica, no técnica
 - Fortalecer el marco regulatorio de protección de datos

Conclusiones

Este incidente demuestra que las **amenazas cibernéticas afectan operativamente y pueden comprometer la sostenibilidad y confianza de la organización**. La participación de actores estatales (**Ejército Popular de Liberación de China**) confirma que los **ataques** pueden suceder súbitamente o con fines lucrativos.

Por ello, le solicitamos a la alta dirección que pueda enfatizar atención en:

Priorizar la ciberseguridad como un eje estratégico, no solo técnico.

Invertir en monitoreo proactivo y segmentación de accesos, evitando que una vulnerabilidad comprometa múltiples sistemas.

Fortalecer la gobernanza de datos, garantizando que la información crítica esté protegida bajo controles estrictos.

Establecer planes de respuesta y comunicación claros, que permitan actuar con rapidez y transparencia ante incidentes.

Fuentes consultadas

Alhassan, I., & Adjei, E. (2022). A systematic study of the control failures in the Equifax cybersecurity incident. ResearchGate.

https://www.researchgate.net/publication/358174136_A_Systematic_Study_of_the_Control_Failures_in_the_Equifax_Cybersecurity_Incident

BBC News. (2019, July 22). Equifax to pay up to \$700m in data breach settlement.

<https://www.bbc.com/news/technology-49070596>

Equifax. (2017, Septiembre 7). Equifax cybersecurity incident. Equifax.

<https://www.equifaxsecurity2017.com/>

Esposito, J. (8 de septiembre de 2017). Fuga de datos de Equifax: ¿qué pasó y qué se puede hacer? Blog oficial de Kaspersky. <https://latam.kaspersky.com/blog/equifax-breach/11240/>

Federal Bureau of Investigation. (2020, February 10). Chinese hackers charged in Equifax breach. FBI. <https://www.fbi.gov/news/stories/chinese-hackers-charged-in-equifax-breach-021020>

Huntress. (s. f.). Equifax data breach. Threat Library. <https://www.huntress.com/threat-library/data-breach/equifax-data-breach>

(House Committee on Oversight and Government Reform). The Equifax Data Breach Report (Diciembre, 2018).

Ontiveros, V. (2021, 15 junio). Equifax data breach. The Belfer Center For Science And International Affairs. <https://www.belfercenter.org/publication/equifax-data-breach>

Rothke, B. (2019, 4 febrero). Nueve lecciones aprendidas a partir de la violación de datos de Equifax. <https://www.beyondtrust.com/es/blog/entry/9-infosec-lessons-from-the-equifax-data-breach>

U.S. Department of Justice. (2020, February 10). Chinese military personnel charged with computer fraud, economic espionage and wire fraud hacking. Office of Public Affairs.

<https://www.justice.gov/archives/opa/pr/chinese-military-personnel-charged-computer-fraud-economic-espionage-and-wire-fraud-hacking>

U.S. Department of Justice. (2020, February 10). Chinese military personnel charged with computer fraud, economic espionage, and wire fraud for hacking. Office of Public Affairs.

<https://www.justice.gov/archives/opa/pr/chinese-military-personnel-charged-computer-fraud-economic-espionage-and-wire-fraud-hacking>

U.S. Government Accountability Office. (2018). Data protection: Actions taken by Equifax and federal agencies in response to the 2017 breach (GAO-18-559).

<https://www.gao.gov/assets/700/694347.pdf>

(Securities and Exchange Commission - SEC). Equifax Inc. Form 8-K (15 de septiembre de 2017).